

- **Expediente N.º: EXP202310796**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 13 de julio de 2023, **A.A.A.** (en adelante, la parte reclamante) interpuso reclamación ante la Agencia Española de Protección de Datos.

La reclamación se dirige contra AYUNTAMIENTO DE MONTEMAYOR DE PILILLA, con NIF P4709400H (en adelante, Ayuntamiento o parte reclamada).

Los motivos en que basa la reclamación son los siguientes:

(...).

El *****FECHA.1**, el Alcalde del citado municipio, publicó en la plataforma pública "Bando Móvil" (puede leer cualquiera que se descargue dicha aplicación y a la que tienen accesos todos los vecinos del municipio), un comunicado sobre la parte reclamante en el que vertía una serie de difamaciones y falsedades, (...).

La reclamante indica que envió (...) y que la publicación de tales datos que afectan a su intimidad y a su salud, sin haber consentido al Alcalde ni al Ayuntamiento su uso y difusión.

Aporta los siguientes documentos:

- a) Comunicado del Alcalde de Montemayor de Pililla, de fecha de *****FECHA.1**;
- b) imagen de la publicación en la plataforma 'Bando Móvil', de fecha de *****FECHA.1** (...).

SEGUNDO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGDD), el 2 de agosto de 2023 se dio traslado de dicha reclamación a la parte reclamada, y se reiteró en dos ocasiones más, los días 14 de agosto de 2023 y el 4 de octubre de 2023, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado remitido por vía postal el 14 de agosto de 2023 fue recogido por el Ayuntamiento el 30 de agosto de 2023.

Sin embargo, no se recibió respuesta a este escrito de traslado.

TERCERO: Con fecha 13 de octubre de 2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: Con fecha 30 de enero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, por la presunta infracción del artículo 5.1.f) del RGPD, artículo 9 del RGPD y artículo 32 del RGPD, tipificada en el artículo 83.4 del RGPD esta última y en el artículo 83.5 del RGPD las dos primeras.

QUINTO: Con fecha 16 de febrero de 2023, en respuesta al acuerdo de inicio, se presentan las siguientes manifestaciones por la parte reclamada:

“Este Ayuntamiento no ha contestado al traslado, inicial, de la reclamación con los requerimientos efectuados por la AEPD, para su análisis y remitir información, por carecer de funcionario técnico estable, pues en el periodo de los hechos, y en pocos meses han ejercido (...). Por lo que ha habido periodos de tiempo que el Ayuntamiento ha carecido de (...), que asesorese sobre la normativa de protección de datos y diese cumplimiento a los requerimientos.

Respecto al Bando Móvil informaba de una situación concreta del servicio de (...), que el Ayuntamiento debe prestar a los ciudadanos y que los días indicados no se presentaron, al no hacer acto de presencia (...). El medio porque se informó fue a través de un Bando que es un acto administrativo, no normativo, competencia del alcalde, consistente en una manifestación o información que se dirige a los ciudadanos, en este caso, informando a los vecinos de la carencia del servicio de Secretaría.

Dicha competencia viene establecida en el artículo 21.1, e), artículo 124.4, g) Ley 7/1985, de 2 de abril, Reguladora de las Bases del Régimen Local.

Indica la reclamante, que el Bando móvil exponía una serie de difamaciones y falsedades, lo cual no es cierto, pues los hechos indicados en el Bando son ciertos y así se puede demostrar. Me remito a los archivos de las administraciones correspondientes. Pero considero que esa no es la cuestión que se plantea en un expediente sancionador de protección de datos personales. La reclamante, debería haber utilizado otra vía jurídica para reclamar por difamación y falsedad. La reclamante está utilizando la vía administrativa sancionadora de la AEPD, como medio para perjudicar al Ayuntamiento de Montemayor de Pililla.

La indicación que hace el Bando de no asistencia al puesto de trabajo de la reclamante por “(...)”, es una manifestación en relación con la relación de prestación de servicios, por la que se informa que (...) era por dichas causas.

La expresión “(...)” no vulnera su derecho a la intimidad o de salud, pues nada se indica sobre la posible enfermedad, o asistencia al médico para sí u otra persona, etc., sino que es una expresión que informa de la justificación de la no presencia de la reclamante en el Ayuntamiento.

Dicho Bando fue dictado dentro de las atribuciones de los alcaldes, que desempeñan

la jefatura superior de todo el personal, conforme establece el artículo 21.1, h) de la Ley de Bases de Régimen Local.

Los hechos denunciados por la reclamante no vulneran el derecho a proteger sus datos personales y de salud, dado que no menciona nombre, sino el cargo del propio Ayuntamiento y no indica ningún dato de salud. Por lo que, los datos han sido tratados manera que garantiza una seguridad adecuada de sus datos personales, por lo que no existe una falta de medidas técnicas y organizativas al no haberse exhibido datos personales, ni de salud. ´

No ha existido vulneración de los datos relativos a la salud, pues la expresión “(...)” no revela ningún dato de salud, y se refiere a una justificación de carácter laboral, por la que produjo la no asistencia al puesto de trabajo de la reclamante. Y, en el supuesto de considerarse aplicable el precepto al hecho denunciado, este no sería de aplicación por ser el tratamiento necesario para el cumplimiento de obligaciones y el ejercicio de derechos específicos del responsable del tratamiento o del interesado en el ámbito del Derecho laboral y de la seguridad y protección social, en la medida en que así lo autorice el Derecho de la Unión de los Estados miembros o un convenio colectivo con arreglo al Derecho de los Estados miembros que establezca garantías adecuadas del respeto de los derechos fundamentales y de los intereses del interesado. Conforme establece el art. 5.2. b) del Reglamento.

Había medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo. Los hechos denunciados no suponen la falta de medidas técnicas u organizativas, además el RGPD no establece un listado de dichas medidas.

La reclamante conocía, por su cargo, la existencia de información sobre el tratamiento de datos personales del Ayuntamiento, y la forma de ejercerlos, pues dicha información está en la página Web del Ayuntamiento. No obstante, no ejerció los derechos que le asisten, como son el derecho de rectificación, supresión, limitación del tratamiento y oposición.

No existe infracción de la normativa de protección de datos personales, por lo que no procede la aplicación de ninguna sanción.”

SEXTO: El 17 de abril de 2024 de remite propuesta de resolución a la parte reclamada, proponiendo lo siguiente:

Que por la Directora de la Agencia Española de Protección de Datos se declare que el Ayuntamiento de Montemayor de Pililla, ha infringido lo dispuesto en el Artículo 5.1.f) del RGPD, Artículo 9 del RGPD y Artículo 32 del RGPD, tipificada en el artículo 83.4 del RGPD esta última y en el artículo 83.5 del RGPD las dos primeras.

Que por la Directora de la Agencia Española de Protección de Datos se ordene al Ayuntamiento de Montemayor de Pililla, que en virtud del artículo 58.2.d) del RGPD, en el plazo de un mes se notifique a esta Agencia la adopción de medidas que respeten el principio de integridad y confidencialidad establecido en el artículo 5.1 f) del RGPD, garantizando una seguridad adecuada de los datos personales, para evitar que se vulneren el principio de integridad y confidencialidad de los datos personales,

tal y como exige el artículo 5.1 f) del RGPD, en especial los datos de salud, ya que son considerados especialmente sensibles, de conformidad con el artículo 9 del RGPD y la adopción de medidas necesarias para evitar que tales hechos se repitan, de conformidad con el artículo 32 del RGPD.

SEPTIMO: En respuesta a la propuesta de resolución de fecha 17 de abril de 2024, la parte reclamada formuló alegaciones en el que, además de lo indicado en su escrito de alegaciones a la apertura del procedimiento, expone lo siguiente:

“Me afirmo y ratifico en la Alegaciones formuladas, por escrito de fecha 15/02/2024, contra la resolución de incoación del procedimiento sancionador, dándolas por reproducidas en las presentes alegaciones.

Primera.- Las expresiones contenidas en el bando móvil del Ayuntamiento no afecta a la intimidad, ni a datos de salud de la reclamante.

(...)

Dicho Bando fue dictado dentro de las atribuciones de los Alcaldes, que desempeñan la jefatura superior de todo el personal, conforme establece el artículo 21.1, h) de la Ley de Bases de Régimen Local.

Por lo que no se ha infringido la normativa de protección de datos, pues el Ayuntamiento reclamada si tenía legitimación para el tratamiento de la información aludida, no siendo necesario el consentimiento de la parte reclamada. La difusión de datos era de carácter informativo para los ciudadanos del municipio, por lo que no procedía la apertura del procedimiento sancionador, conforme establece el artículo 58.2 RGPD.

Segunda.- Respecto a las posibles infracciones que establece la Propuesta de Resolución del procedimiento sancionador.

1.- Artículo 5.1, f) del RGPD. Principios relativos al tratamiento de los datos personales.

Los hechos denunciados por la reclamante no vulneran el derecho a proteger sus datos personales y de salud, dado que no menciona nombre, sino un servicio del Ayuntamiento que no se podía prestar por la falta de personal y no se indicaba ningún dato de salud de la reclamante.

Por lo que, los datos han sido tratados manera que garantiza una seguridad adecuada de sus datos personales, por lo que no existe una falta de medidas técnicas y organizativas al no haberse exhibido datos personales, ni de salud.

2.- Artículo 9 del RGPD. Tratamiento de categorías especiales de datos personales.

(...)

3.- Artículo 32 RGPD. Seguridad del tratamiento.

Había medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo. Los hechos denunciados no suponen la falta de medidas técnicas u organizativas, además el RGPD no establece un listado de dichas medidas.

(...)

Cuarta. - No procede la aplicación de sanciones.

No existe infracción de la normativa de protección de datos personales, por lo que no procede la aplicación de ninguna sanción.

Quinta. - Propuestas de medidas de seguridad.

Respecto a la imposición de la adopción de las medidas adecuadas que respeten los principios de integridad y confidencialidad, cabe señalar que el RGPD NO establece un listado de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que se establece que se aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleven el tratamiento.

No obstante, la carencia de un listado de medidas de seguridad, el Ayuntamiento reclamado establecerá medidas de seguridad teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidad del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Medidas de seguridad que proponen adoptar:

1.- Descripción de las medidas técnicas y organizativas de seguridad.

Teniendo como guía el Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad, se aplicarán las medidas de protección siguientes:

- . Protección de las instalaciones e infraestructuras*
- . Gestión de Personal*
- . Protección de los equipos*
- . Protección de las comunicaciones*
- . Protección de los soportes de información.*
- . Protección de las aplicaciones informáticas.*
- . Protección de la información.*
- . Protección de los servicios*
- . Protección del correo electrónico.*
- . Protección de servicios y aplicaciones web.*
- . Protección de la navegación web.*

2.- Aplicación de las medidas de seguridad contenidas en las guías de protección datos personales: protección de datos y administración local guía estratégica en seguridad para entidades locales, guía para entidades locales de menos de 2.000 habitantes.

- . *Identificación y autenticación de los usuarios*
- . *En un equipo solo existirán aquellos usuarios locales que pueden iniciar sesión en el mismo.*
- . *En ningún caso se mantendrán escritas las contraseñas de acceso al equipo cerca del escritorio, ni en ningún sitio que pueda ser identificada su finalidad.*
- . *La cuenta de administrador estará, únicamente, en manos del responsable de la seguridad de la información, y deberá ser cambiada cada vez que por razones técnicas deba ser conocida por otra persona, por ejemplo, del servicio técnico.*
- . *Los cambios de personal funcionario, implicarán el cambio de las contraseñas de todos los equipos, servicios y sistemas a los que el personal saliente tuviera acceso.*
- . *Tras un periodo de inactividad, el equipo debe estar configurado para bloquearse automáticamente, de forma que requiera introducir la clave de acceso de nuevo, esto supone que, ante un eventual abandono del puesto de trabajo, el equipo no quedará accesible de forma indefinida.*
- . *Si existen carpetas compartidas, se prestará especial atención a la pestaña de seguridad de los archivos y carpetas, que indica la disponibilidad de las mismas para los usuarios locales, y para los que acceden desde la red.*

3.- Formación y concienciación.

Periódicamente la Diputación Provincial de Valladolid organizará cursos de formación y actualización en materia de seguridad de la información, los cuales serán de asistencia obligatoria, al menos, para el Responsable de Seguridad de Sistemas de Información Municipal.

Sexta.- Compromisos del Ayuntamiento de Montemayor de Pililla.

- 1.- *Ha sido eliminado el Bando Móvil objeto de la denuncia.*
- 2.- *Publicación de Declaración Institucional del Ayuntamiento sobre el compromiso con la Protección de Datos Personales. Adjunto documento de compromiso.*
- 3.- *Cumplimiento de la normativa de Protección de Datos Personales (RGPD y LOPDGDD)".*

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: El *****FECHA.1**, el Alcalde del citado municipio, publicó en la plataforma pública "Bando Móvil" lo siguiente:

“*FECHA.1**

(...).

(...).

(...)

(...).".

FUNDAMENTOS DE DERECHO

I

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento, la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II

Cuestiones previas

En el presente caso, la parte reclamante manifiesta que el *****FECHA.1**, el Ayuntamiento de Montemayor de Pililla publicó en la plataforma pública "Bando Móvil", un comunicado en el que vertía una serie de difamaciones y falsedades relativas a la misma, detallando que los (...).

La parte reclamante indica que envió (...) y que la publicación de tales datos afecta a su intimidad y a su salud, sin haber consentido su uso y difusión.

La parte reclamada realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD:

«responsable del tratamiento» o «responsable»: *la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros.*

III

Respuesta a las Alegaciones presentadas por la parte reclamada

Antes de proceder a dar respuesta a las alegaciones presentadas por la parte reclamada ha de indicarse que el artículo 4 del RGPD define datos personales como *“toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.”*

1. La parte reclamada ha manifestado que la información contenida en el bando móvil objeto de la reclamación no afecta al derecho a la protección de datos personales, dado que no menciona el nombre de la parte reclamante. Sin embargo, debe indicarse que la parte reclamante (...), la indicación del mismo en el bando permite su identificación, aun sin mencionar su nombre de forma explícita.

2. La parte reclamada señala, por otra parte, que la expresión “(…)” no revela ningún dato de salud.

Los datos de salud constituyen una categoría especial de datos, conforme al art. 9.1 del RGPD, cuyo tratamiento está prohibido con carácter general, salvo que concurren determinadas excepciones contempladas en el punto 2 del referido art. 9 del RGPD.

El RGPD define en su artículo 4.15 los datos relativos a la salud como los *“datos personales relativos a la salud física o mental de una persona física, incluida la prestación de servicios de atención sanitaria, que revelen información sobre su estado de salud.”*

El considerando 35 del RGPD aclara dicha definición señalando que *“Entre los datos personales relativos a la salud se deben incluir todos los datos relativos al estado de salud del interesado que dan información sobre su estado de salud física o mental pasado, presente o futuro. Se incluye la información sobre la persona física recogida con ocasión de su inscripción a efectos de asistencia sanitaria, o con ocasión de la prestación de tal asistencia, de conformidad con la Directiva 2011/24/UE del Parlamento Europeo y del Consejo; todo número, símbolo o dato asignado a una persona física que la identifique de manera unívoca a efectos sanitarios; la información obtenida de pruebas o exámenes de una parte del cuerpo o de una sustancia corporal, incluida la procedente de datos genéticos y muestras biológicas, y cualquier información relativa, a título de ejemplo, a una enfermedad, una discapacidad, el riesgo de padecer enfermedades, el historial médico, el tratamiento clínico o el estado fisiológico o biomédico del interesado, independientemente de su fuente, por ejemplo un médico u otro profesional sanitario, un hospital, un dispositivo médico, o una prueba diagnóstica in vitro.”*

El Tribunal de Justicia (TJUE) interpretó dicho concepto en un sentido amplio, considerando como datos relativos a la salud, la información relativa a todos los aspectos, tanto físicos como psíquicos, de la salud de una persona, tanto relativo a su estado de salud como que la misma se encuentra en una situación de baja parcial

(STJUE de 6 de noviembre de 2003, Lindqvist, C-101/01).

Es más, el TJUE en su sentencia de 1 de agosto de 2022, en el asunto, C-184/20, OT, fija una interpretación amplia del concepto categorías especiales de datos personales:

“125 Además, una interpretación amplia de los conceptos de «categorías especiales de datos personales» y de «datos sensibles» se ve respaldada por el objetivo de la Directiva 95/46 y del RGPD, a que se ha hecho mención en el apartado 61 de la presente sentencia, de asegurar un alto nivel de protección de las libertades y de los derechos fundamentales de las personas físicas, en particular, de su intimidad, en relación con el tratamiento de los datos personales que las afectan (véase, en este sentido, la sentencia de 6 de noviembre de 2003, Lindqvist, C 101/01, EU:C:2003:596, apartado 50).

126 Más aún, la interpretación contraria se opondría a la finalidad del artículo 8, apartado 1, de la Directiva 95/46 y del artículo 9, apartado 1, del RGPD, que consiste en garantizar una mayor protección frente a tales tratamientos, que, en atención a la particular sensibilidad de los datos objeto de ellos, pueden constituir, como se desprende del considerando 33 de la Directiva 95/46 y del considerando 51 del RGPD, una injerencia especialmente grave en los derechos fundamentales al respeto de la vida privada y a la protección de los datos personales, garantizados por los artículos 7 y 8 de la Carta [véase, en este sentido, la sentencia de 24 de septiembre de 2019, GC y otros (Retirada de enlaces a datos sensibles), C 136/17, EU:C:2019:773, apartado 44]”.

127 Por consiguiente, no cabe interpretar tales disposiciones en el sentido de que el tratamiento de datos personales que puedan desvelar indirectamente informaciones sensibles sobre una persona física queda fuera del régimen de protección reforzado establecido por las mencionadas disposiciones, pues de quedar fuera se menoscabaría el efecto útil de ese régimen y la protección de las libertades y de los derechos fundamentales de las personas físicas que pretende garantizar”.

3. No se cuestiona en el presente acto la veracidad o no de la información que se ofrece en el bando móvil objeto de las actuaciones, cuya apreciación y consecuencias no corresponde a esta Agencia, ni tampoco las atribuciones que tiene un ayuntamiento para informar a sus ciudadanos sobre asuntos de la corporación que resulten de interés para los mismos. Interesa al presente procedimiento el uso dado a los datos personales de la parte reclamante y si ese uso se ajusta a la normativa de aplicación.

4. Por otro lado, la parte reclamada señala que en dicho tratamiento se utilizaban medidas técnicas apropiadas. Sin embargo, no ha aportado documentación alguna que así o acredite. Al contrario, en sus escritos de alegaciones se hace referencia únicamente a las medidas que tiene previsto implantar.

5. Se afirma además que, si bien la parte reclamante conocía la existencia de información sobre el tratamiento de datos personales del Ayuntamiento, que incluye la forma de ejercer los derechos en materia de protección de datos, la misma no ha ejercitado ninguno de ellos.

Debe señalarse al respecto que la posibilidad de formular una reclamación ante la

autoridad de control es un derecho reconocido a los ciudadanos que no requiere, como presupuesto previo, el ejercicio de ningún derecho, salvo que la reclamación se refiere propiamente a la no atención de un derecho, circunstancia que no se da en el presente caso.

IV

Artículo 5.1.f) del RGPD

Los hechos puestos de manifiesto se concretan en la existencia de una brecha de datos personales consecuencia de la difusión de datos personales de la parte reclamante a través de la plataforma del Ayuntamiento denominada Bando Móvil. Ello posibilitó el acceso no autorizado por terceros a los datos personales de la parte reclamante, concretamente, el (...).

Respecto de estos hechos, la parte reclamada actúa como responsable del tratamiento. Como tal, viene obligada a demostrar el cumplimiento RGPD y de la LOPDGDD y a aplicar las medidas técnicas y organizativas que garanticen la seguridad de los datos personales al llevar a cabo el tratamiento, conforme a lo establecido en el artículo 5.1.f) del RGPD, según el cual:

“Artículo 5 Principios relativos al tratamiento:

1. *Los datos personales serán:*

(...)

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

En relación con este principio, el Considerando 39 del referido RGPD señala que:

“[...]Los datos personales deben tratarse de un modo que garantice una seguridad y confidencialidad adecuadas de los datos personales, inclusive para impedir el acceso o uso no autorizados de dichos datos y del equipo utilizado en el tratamiento”.

La documentación obrante en el expediente ofrece hechos probados de que el reclamado vulneró el artículo 5.1 f) del RGPD, sobre los *principios relativos al tratamiento*.

La documentación obrante en el expediente ofrece evidencias suficientes de que la parte reclamada vulneró el artículo 5.1 del RGPD, *principios relativos al tratamiento*, al producirse una brecha de datos personales que tuvo como causa la publicación de una información relativa a la parte reclamante con indicación de datos personales que le conciernen, no habiendo garantizado debidamente la confidencialidad e integridad de los datos.

En este sentido, el citado art. 5.1.f) del RGPD, prevé que los datos personales serán tratados de tal manera que se garantice su seguridad, incluida la protección contra el

tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas.

Y es que la pérdida de confidencialidad supone un riesgo, que puede conllevar daños y perjuicios, materiales o inmateriales para las personas físicas (considerando 85 del RGPD). En tal sentido, el considerando 75 del RGPD establece que: *“Los riesgos para los derechos y libertades de las personas físicas, de gravedad y probabilidad variables, pueden deberse al tratamiento de datos que pudieran provocar daños y perjuicios físicos, materiales o inmateriales, en particular en los casos en los que el tratamiento pueda dar lugar a problemas de discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, reversión no autorizada de la seudonimización o cualquier otro perjuicio económico o social significativo; en los casos en los que se prive a los interesados de sus derechos y libertades o se les impida ejercer el control sobre sus datos personales; ...”*.

Por tanto, el acceso no autorizado a los datos de carácter personal supone que éstos puedan ser utilizados para usos no conocidos, incluso fraudulentos, conllevando una pérdida total y absoluta de control sobre los mismos.

En este mismo sentido, el artículo 28.2 de la LOPDGDD, y respecto de las obligaciones del responsable del tratamiento en el marco de los artículos 24 y 25 del RGPD para garantizar y acreditar que el tratamiento es conforme al RGPD respecto de diversos riesgos, dispone que:

“2. Para la adopción de las medidas a que se refiere el apartado anterior los responsables y encargados del tratamiento tendrán en cuenta, en particular, los mayores riesgos que podrían producirse en los siguientes supuestos:

a) Cuando el tratamiento pudiera generar situaciones de discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, reversión no autorizada de la seudonimización o cualquier otro perjuicio económico, moral o social significativo para los afectados. ...”

Y la Sentencia del Tribunal Constitucional (STC) 292/2000 en el FD séptimo, señala: *“... resulta que el contenido del derecho fundamental a la protección de datos consiste en un poder de disposición y de control sobre los datos personales que faculta a la persona para decidir cuáles de esos datos proporcionar a un tercero, sea el Estado o un particular, o cuáles puede este tercero recabar, y que también permite al individuo saber quién posee esos datos personales y para qué, pudiendo oponerse a esa posesión o uso. Estos poderes de disposición y control sobre los datos personales, que constituyen parte del contenido del derecho fundamental a la protección de datos se concretan jurídicamente en la facultad de consentir la recogida, la obtención y el acceso a los datos personales, su posterior almacenamiento y tratamiento, así como su uso o usos posibles, por un tercero, sea el Estado o un particular.”*

Por todo lo expuesto, se consideran que los hechos acontecidos son constitutivos de una infracción, imputable al Ayuntamiento reclamado, por vulneración del artículo 5.1.f) del RGPD.

V

Tipificación de la infracción del artículo 5.1.f) del RGPD

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de la infracción tipificada en el artículo 83.5 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*”, letra a), que dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

- a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)*”

A este respecto, la LOPDGDD, en su artículo 71 “*Infracciones*” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 72 “*Infracciones consideradas muy graves*” de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

- a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)*”

VI

Artículo 32 del RGPD

Establece el artículo 32 del RGPD, *seguridad del tratamiento*, lo siguiente:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos*

*personales de forma rápida en caso de incidente físico o técnico;
d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

Los hechos puestos de manifiesto suponen la falta de medidas de seguridad que han posibilitado la difusión de datos de carácter personal de la parte reclamante en la plataforma pública "Bando Móvil", pese a no contar con base jurídica para dicho tratamiento.

Hay que señalar que el RGPD en el citado precepto no establece un listado de las medidas de seguridad que sean de aplicación de acuerdo con los datos que son objeto de tratamiento, sino que establece que el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas que sean adecuadas al riesgo que conlleve el tratamiento, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento, los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Asimismo, las medidas técnicas y organizativas apropiadas de seguridad deben resultar adecuadas y proporcionadas al riesgo detectado, señalando que la determinación de las medidas técnicas y organizativas deberá realizarse teniendo en cuenta: la seudonimización y el cifrado, la capacidad para garantizar la confidencialidad, integridad, disponibilidad y resiliencia, la capacidad para restaurar la disponibilidad y acceso a datos tras un incidente, proceso de verificación (que no auditoría), evaluación y valoración de la eficacia de las medidas.

En todo caso, al evaluar la adecuación del nivel de las medidas técnicas y organizativas de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos y que pudieran ocasionar daños y perjuicios físicos, materiales o inmateriales.

En este mismo sentido el considerando 83 del RGPD señala que:

“(83) A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales”.

La responsabilidad de la parte reclamada viene determinada por la falta de medidas técnicas y organizativas adecuadas para garantizar un nivel de seguridad adecuado al riesgo, ya que es responsable de tomar decisiones destinadas a implementar de manera efectiva dichas medidas. En el presente caso, se evidencia que el Ayuntamiento reclamado, en relación con los datos sometidos a tratamiento, no tiene implantadas medidas de seguridad adecuadas, con independencia de la brecha.

Hay que insistir que la adecuación del nivel de seguridad al riesgo debe ser evaluada por el responsable y reconsiderada periódicamente en función de los resultados obtenidos, teniendo en cuenta para ello -entre otros factores- los riesgos que pueda presentar el tratamiento como consecuencia de la comunicación no autorizada de dichos datos. Las medidas técnicas y organizativas de seguridad que deben de aplicarse son las pertinentes para responder al riesgo existente, valorando, entre otros factores, el estado de la técnica, los costes de aplicación, la naturaleza, alcance, contexto y finalidades del tratamiento y los riesgos de probabilidad y gravedad para los derechos y libertades de las personas interesadas.

Uno de los requerimientos que establece el RGPD para responsables y encargados del tratamiento que realizan actividades de tratamiento con datos personales es la necesidad de llevar a cabo un análisis de riesgos de la seguridad de la información con el fin de establecer las medidas de seguridad y control orientadas a cumplir los principios de protección desde el diseño y por defecto que garanticen los derechos y libertades de las personas.

La ausencia de medidas técnicas y organizativas de seguridad adecuadas constatada, que ha dado lugar a la difusión de los datos personales de la parte reclamante en la plataforma pública "Bando Móvil" a la que tienen acceso todos los ciudadanos del citado municipio, supone una infracción de lo establecido en el artículo 32 RGPD.

VII

Tipificación de la infracción del artículo 32 del RGPD

La citada vulneración del artículo 32 del RGPD supone la comisión de la infracción tipificada en el artículo 83.4 del RGPD *“Condiciones generales para la imposición de*

multas administrativas”, letra a), que dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

- a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...).”*

A este respecto, la LOPDGDD, en su artículo 71 “Infracciones” establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.*

A efectos del plazo de prescripción, el artículo 73 “Infracciones consideradas graves” de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

- f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.”*

VIII Artículo 9 del RGPD

El artículo 4 del RGPD, define los datos relativos a la salud de la siguiente manera, *“datos personales relativos a la salud física o mental de una persona física, incluida la prestación de servicios de atención sanitaria, que revelen información sobre su estado de salud”.*

Por su parte, el artículo 9 del RGPD establece lo siguiente:

“1. Quedan prohibidos el tratamiento de datos personales que revelen el origen étnico o racial, las opiniones políticas, las convicciones religiosas o filosóficas, o la afiliación sindical, y el tratamiento de datos genéticos, datos biométricos dirigidos a identificar de manera unívoca a una persona física, datos relativos a la salud o datos relativos a la vida sexual o las orientaciones sexuales de una persona física.

2. El apartado 1 no será de aplicación cuando concurra una de las circunstancias siguientes:

- a) el interesado dio su consentimiento explícito para el tratamiento de dichos datos personales con uno o más de los fines especificados, excepto cuando el Derecho de la Unión o de los Estados miembros establezca que la prohibición mencionada en el apartado 1 no puede ser levantada por el interesado;*

- b) el tratamiento es necesario para el cumplimiento de obligaciones y el ejercicio de derechos específicos del responsable del tratamiento o del interesado en el ámbito del Derecho laboral y de la seguridad y protección social, en la medida en que así lo autorice el Derecho de la Unión de los Estados miembros o un convenio colectivo con arreglo al Derecho de los Estados miembros que establezca garantías adecuadas del respeto de los derechos fundamentales y de los intereses del interesado;
- c) el tratamiento es necesario para proteger intereses vitales del interesado o de otra persona física, en el supuesto de que el interesado no esté capacitado, física o jurídicamente, para dar su consentimiento;
- d) el tratamiento es efectuado, en el ámbito de sus actividades legítimas y con las debidas garantías, por una fundación, una asociación o cualquier otro organismo sin ánimo de lucro, cuya finalidad sea política, filosófica, religiosa o sindical, siempre que el tratamiento se refiera exclusivamente a los miembros actuales o antiguos de tales organismos o a personas que mantengan contactos regulares con ellos en relación con sus fines y siempre que los datos personales no se comuniquen fuera de ellos sin el consentimiento de los interesados;
- e) el tratamiento se refiere a datos personales que el interesado ha hecho manifiestamente públicos;
- f) el tratamiento es necesario para la formulación, el ejercicio o la defensa de reclamaciones o cuando los tribunales actúen en ejercicio de su función judicial;
- g) el tratamiento es necesario por razones de un interés público esencial, sobre la base del Derecho de la Unión o de los Estados miembros, que debe ser proporcional al objetivo perseguido, respetar en lo esencial el derecho a la protección de datos y establecer medidas adecuadas y específicas para proteger los intereses y derechos fundamentales del interesado;
- h) el tratamiento es necesario para fines de medicina preventiva o laboral, evaluación de la capacidad laboral del trabajador, diagnóstico médico, prestación de asistencia o tratamiento de tipo sanitario o social, o gestión de los sistemas y servicios de asistencia sanitaria y social, sobre la base del Derecho de la Unión o de los Estados miembros o en virtud de un contrato con un profesional sanitario y sin perjuicio de las condiciones y garantías contempladas en el apartado 3;
- i) el tratamiento es necesario por razones de interés público en el ámbito de la salud pública, como la protección frente a amenazas transfronterizas graves para la salud, o para garantizar elevados niveles de calidad y de seguridad de la asistencia sanitaria y de los medicamentos o productos sanitarios, sobre la base del Derecho de la Unión o de los Estados miembros que establezca medidas adecuadas y específicas para proteger los derechos y libertades del interesado, en particular el secreto profesional,
- j) el tratamiento es necesario con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos, de conformidad con el artículo 89, apartado 1, sobre la base del Derecho de la Unión o de los Estados miembros, que debe ser proporcional al objetivo perseguido, respetar en lo esencial el derecho a la protección de datos y establecer medidas adecuadas y específicas para proteger los intereses y derechos fundamentales del interesado.

3. Los datos personales a que se refiere el apartado 1 podrán tratarse a los fines citados en el apartado 2, letra h), cuando su tratamiento sea realizado por un profesional sujeto a la obligación de secreto profesional, o bajo su responsabilidad, de acuerdo con el Derecho de la Unión o de los Estados miembros o con las normas establecidas por los organismos nacionales competentes, o por cualquier otra persona sujeta también a la obligación de secreto de acuerdo con el Derecho de la Unión o de los Estados miembros o de las normas establecidas por los organismos nacionales

competentes.

4. Los Estados miembros podrán mantener o introducir condiciones adicionales, inclusive limitaciones, con respecto al tratamiento de datos genéticos, datos biométricos o datos relativos a la salud”.

En el presente caso, pese a no incurrir en ninguno de los supuestos recogidos en el artículo 9.2 del RGPD que levantan la prohibición de tratar esas categorías de datos personales, , entre las que se incluyen los datos personales relativos a la salud de los interesados, la parte reclamada ha hecho uso de datos de salud de la parte reclamante al incluirlos sin justificación para ello en la información publicada a través de la plataforma Bando Móvil, señalando que la parte reclamante (...).

Por lo tanto, la parte reclamada ha vulnerado lo establecido en el artículo 9 del RGPD, que prohíbe el tratamiento de datos relativos a la salud si no concurre alguna de las excepciones que se recogen en el apartado 2 de dicho artículo.

IX

Tipificación del artículo 9 del RGPD

La infracción del artículo 9 del RGPD, de la que se responsabiliza a la parte reclamada, está tipificada en el artículo 83.5 del RGPD:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 Eur como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) Los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5,6,7 y 9.”

A su vez, la LOPDGDD en su artículo 72.1.e) califica de infracción muy grave, a efectos de prescripción, *“El tratamiento de datos personales de las categorías a las que se refiere el artículo 9 del Reglamento (UE)2016/679 sin que concorra alguna de las circunstancias previstas en dicho precepto y en el artículo de esta Ley Orgánica.”*

X

Sanción

El artículo 83 “Condiciones generales para la imposición de multas administrativas” del RGPD, en su apartado 7, establece:

“Sin perjuicio de los poderes correctivos de las autoridades de control en virtud del artículo 58, apartado 2, cada Estado miembro podrá establecer normas sobre si se puede, y en qué medida, imponer multas administrativas a autoridades y organismos públicos establecidos en dicho Estado miembro.”

El artículo 77 “Régimen aplicable a determinadas categorías de responsables o

encargados del tratamiento" de la LOPDGDD dispone lo siguiente:

"1. El régimen establecido en este artículo será de aplicación a los tratamientos de los que sean responsables o encargados:

- a) Los órganos constitucionales o con relevancia constitucional y las instituciones de las comunidades autónomas análogas a los mismos.*
- b) Los órganos jurisdiccionales.*
- c) La Administración General del Estado, las Administraciones de las comunidades autónomas y las entidades que integran la Administración Local.*
- d) Los organismos públicos y entidades de Derecho público vinculadas o dependientes de las Administraciones Públicas.*
- e) Las autoridades administrativas independientes.*
- f) El Banco de España.*
- g) Las corporaciones de Derecho público cuando las finalidades del tratamiento se relacionen con el ejercicio de potestades de derecho público.*
- h) Las fundaciones del sector público.*
- i) Las Universidades Públicas.*
- j) Los consorcios.*
- k) Los grupos parlamentarios de las Cortes Generales y las Asambleas Legislativas autonómicas, así como los grupos políticos de las Corporaciones Locales.*

2. Cuando los responsables o encargados enumerados en el apartado 1 cometiesen alguna de las infracciones a las que se refieren los artículos 72 a 74 de esta ley orgánica, la autoridad de protección de datos que resulte competente dictará resolución declarando la infracción y estableciendo, en su caso, las medidas que proceda adoptar para que cese la conducta o se corrijan los efectos de la infracción que se hubiese cometido, con excepción de la prevista en el artículo 58.2.i del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016.

La resolución se notificará al responsable o encargado del tratamiento, al órgano del que dependa jerárquicamente, en su caso, y a los afectados que tuvieran la condición de interesado, en su caso.

3. Sin perjuicio de lo establecido en el apartado anterior, la autoridad de protección de datos propondrá también la iniciación de actuaciones disciplinarias cuando existan indicios suficientes para ello. En este caso, el procedimiento y las sanciones a aplicar serán las establecidas en la legislación sobre régimen disciplinario o sancionador que resulte de aplicación.

Asimismo, cuando las infracciones sean imputables a autoridades y directivos, y se acredite la existencia de informes técnicos o recomendaciones para el tratamiento que no hubieran sido debidamente atendidos, en la resolución en la que se imponga la sanción se incluirá una amonestación con denominación del cargo responsable y se ordenará la publicación en el Boletín Oficial del Estado o autonómico que corresponda.

4. Se deberán comunicar a la autoridad de protección de datos las resoluciones que recaigan en relación con las medidas y actuaciones a que se refieren los apartados

anteriores.

5. Se comunicarán al Defensor del Pueblo o, en su caso, a las instituciones análogas de las comunidades autónomas las actuaciones realizadas y las resoluciones dictadas al amparo de este artículo.

6. Cuando la autoridad competente sea la Agencia Española de Protección de Datos, esta publicará en su página web con la debida separación las resoluciones referidas a las entidades del apartado 1 de este artículo, con expresa indicación de la identidad del responsable o encargado del tratamiento que hubiera cometido la infracción.

Cuando la competencia corresponda a una autoridad autonómica de protección de datos se estará, en cuanto a la publicidad de estas resoluciones, a lo que disponga su normativa específica.”

Este precepto establece que los procedimientos que tengan causa en infracciones en materia de protección de datos personales cometidas por las categorías de responsables o encargados del tratamiento enumerados en su apartado 1 se resolverán, en todo caso, declarando la infracción.

XI

Adopción de medidas

Asimismo, el citado artículo 77 de la LOPDGDD contempla que la resolución que se dicte pueda establecer las medidas que la entidad infractora deberá adoptar para que cese la conducta infractora, se corrijan los efectos de la infracción que se hubiese cometido y se lleve a cabo la necesaria adecuación, en este caso, a las exigencias contempladas en los artículos 5.1.f), 9 y 32 del RGPD, debiendo, además, aportar los medios acreditativos del cumplimiento de lo requerido.

Así, se podrá requerir a la entidad responsable para que adecúe su actuación a la normativa de protección de datos personales, con el alcance expresado en los anteriores Fundamentos de Derecho.

En el presente acto se establecen las infracciones cometidas y los hechos que dan lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

Durante la tramitación del procedimiento sancionador, la parte reclamada ha comunicado a esta AEPD las medidas correctivas que tiene previsto adoptar con ocasión de los incidentes de seguridad y confidencialidad objeto del expediente, entre las que figuran medidas de seguridad de instalaciones, equipos y servicios (correo electrónico, aplicaciones web y navegación), identificación y autenticación de usuarios o formación y concienciación.

No se cuestiona la validez de estas medidas, pero se declaran insuficientes en la

medida en que ninguna de ellas contempla el establecimiento de mecanismos dirigidos a evitar incidencias como la analizada en el presente caso. Más allá de la eliminación del Bando Móvil objeto de la reclamación y del compromiso de cumplir la normativa de protección de datos personales, expresamente manifestado, ninguna medida dirigida específicamente a evitar la difusión de datos personales a través de las plataformas del Ayuntamiento.

En consecuencia, procede requerir a la parte reclamada para que, en el plazo de tres meses, contado desde la fecha de ejecutividad de la presente resolución sancionadora, adopte las medidas técnicas y organizativas de todo tipo, incluidas las medidas de seguridad apropiadas para garantizar un nivel de seguridad adecuado al riesgo, de forma que se dé cumplimiento a lo establecido en los artículos 5.1.f), 9 y 32 del RGPD, de tal forma que se respeten los principios de integridad y confidencialidad y una seguridad adecuada de los datos personales.

Entre las medidas a adoptar podrá contemplarse el establecimiento de mecanismos previos a la difusión de datos personales para que la misma no se lleve a efecto sin que exista una base jurídica que la legitime.

Se advierte que no atender la orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, a tenor de lo anteriormente expuesto,
la Directora de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: DECLARAR que AYUNTAMIENTO DE MONTEMAYOR DE PILILLA, con NIF P4709400H, ha infringido lo dispuesto en el Artículo 5.1.f) del RGPD, Artículo 9 del RGPD y Artículo 32 del RGPD, infracción tipificada en el Artículo 83.4 del RGPD esta última y en el Artículo 83.5 del RGPD las dos primeras.

SEGUNDO: ORDENAR a AYUNTAMIENTO DE MONTEMAYOR DE PILILLA, que en virtud del artículo 58.2.d) del RGPD, en el plazo de tres meses desde que la presente resolución sea firme y ejecutiva, acredite haber procedido a la adopción de las medidas necesarias para adecuar su actuación a la normativa de protección de datos personales, con el alcance expresado en el Fundamento de Derecho XI de esta resolución; y acredite ante esta Agencia, en el mismo plazo, las medidas adoptadas.

TERCERO: NOTIFICAR la presente resolución a AYUNTAMIENTO DE MONTEMAYOR DE PILILLA.

CUARTO: COMUNICAR la presente resolución al Defensor del Pueblo, de conformidad con lo establecido en el artículo 77.5 de la LOPDGDD.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos